

Architecture serveurs & sécurité —

Concorde Workforce

Référence : RAPPORT_ARCHITECTURE_INFRA — version 1.1 — 2026-05-28 **Périmètre :** infrastructure de production de la plateforme SaaS multi-tenant Concorde Workforce (pointage, gestion du temps, RH). **Auteur :** Équipe technique — Concorde Tech Innovation.

1. Objet du document

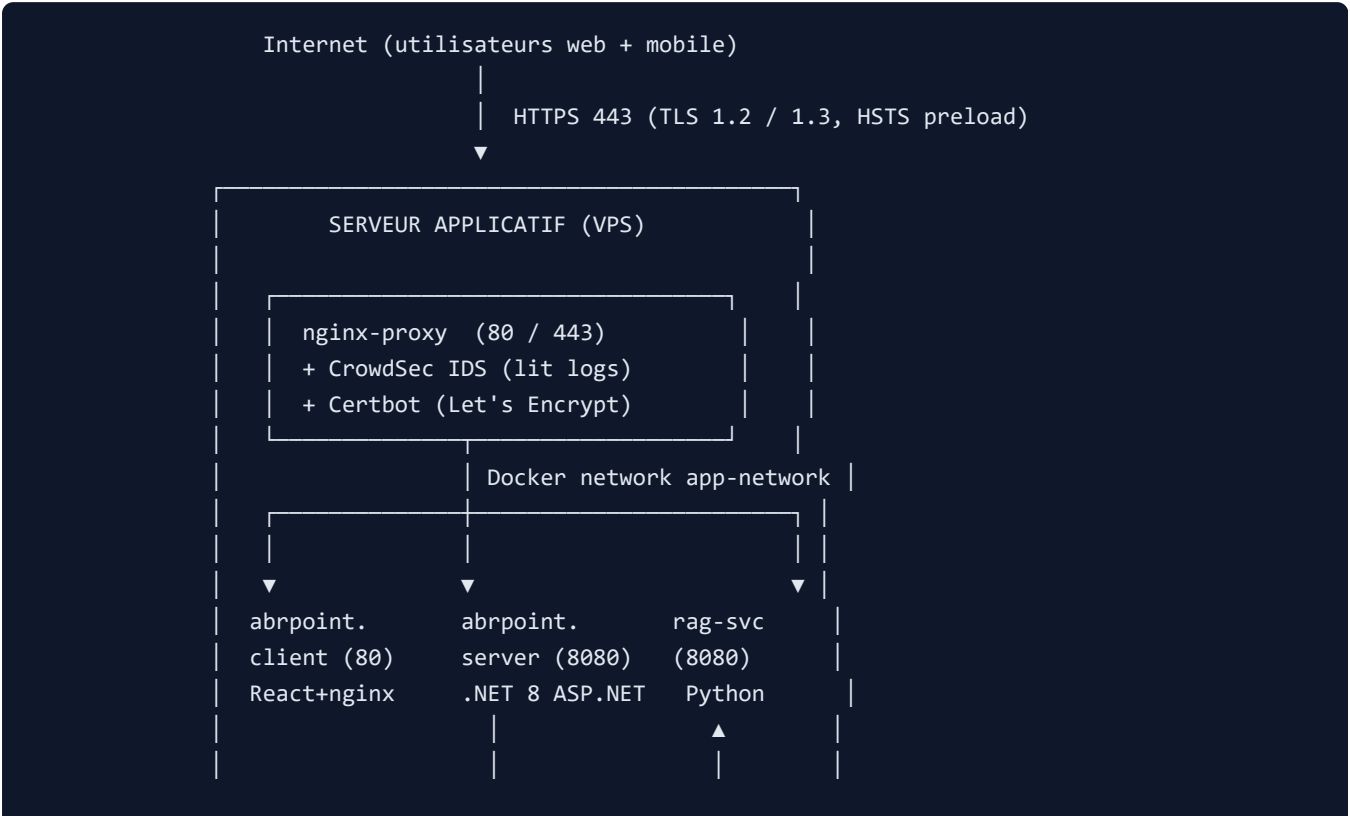
Ce rapport décrit l'architecture des serveurs en production, les flux de communication entre composants, et les mesures de sécurité opérationnelles mises en place. Il s'adresse à un public technique (DSI, DPO, auditeur sécurité, équipe ops) et complète la checklist `SECURITY_INFRA_CHECKLIST.md`.

La plateforme repose sur **deux serveurs distincts**, déployés via Docker Compose :

- un **serveur dédié à la base de données** (PostgreSQL 16 standalone) ;
- un **serveur applicatif** hébergeant le backend .NET, le frontend React, le moteur de recherche vectorielle Qdrant, le micro-service RAG, le reverse-proxy nginx et le système de détection d'intrusion CrowdSec.

Cette séparation physique répond à une exigence de défense en profondeur (Art. 32 RGPD) : la base contenant l'intégralité des données salariés est isolée du serveur exposé à Internet.

2. Vue d'ensemble





Modèle multi-tenant : chaque société cliente dispose de sa propre base PostgreSQL (`tenant_<slug>_<hex>`), provisionnée dynamiquement par le backend à l'inscription. Une base maître (`abrpoint_master`) centralise les métadonnées tenants (statut, plan, clés Stripe, addons souscrits) et l'index global email→slug pour le routage du login.

3. Serveur de base de données

3.1 Composant

Caractéristique	Valeur
Image	postgres:16-alpine
Port d'écoute	5432/tcp
Authentification	scram-sha-256 (forcée via POSTGRES_INITDB_ARGS)
Volume de données	/var/lib/abrpoint/postgres (hôte)
Volume de backups	postgres_backup (Docker named volume)
Connexions max	300
Shared buffers	512 Mo
Logs requêtes lentes	seuil 500 ms
Healthcheck	pg_isready toutes les 10 s

Cf. `docker-compose.db.yml` .

3.2 Bases hébergées

- `abrpoint_master` — créée au premier démarrage. Tables clés : `Tenants` , `TenantEmailIndex` , `RefreshTokens` (révocables). Le superuser `abrpoint` conserve le rôle `CREATEDB` indispensable au provisioning dynamique.
- `tenant_<slug>_<8 chars hex>` — créée à chaque inscription via `ProvisioningService` côté backend. Schéma EF Core migré automatiquement (Code-First). Tables métier : `Utilisateurs` , `Employes` , `Presences` , `Conges` , `Autoriser` , `audit_log` , etc.

3.3 Isolation

Le serveur DB n'héberge **aucun service exposé à Internet** : pas de SSH externe, pas de panel d'admin. Seul le port `5432` est ouvert, restreint au serveur applicatif (cf. §7.1).

4. Serveur applicatif

4.1 Conteneurs

Six services orchestrés via `docker-compose.app.yml` , tous connectés au réseau Docker interne `app-network` :

Conteneur	Image	Port interne	Rôle
<code>nginx-proxy</code>	<code>nginx:alpine</code>	80 / 443 (publics)	Reverse-proxy TLS, terminaison HTTPS, en-têtes de sécurité, routage <code>/api</code> vs SPA
<code>abrpoint.client</code>	<code>mohamedbenrhaïem2003/abrpoint-client</code>	80	SPA React+Vite servie statiquement par un nginx interne
<code>abrpoint.server</code>	<code>mohamedbenrhaïem2003/abrpoint-server</code>	8080	API REST .NET 8 (ASP.NET Core, EF Core, Npgsql)
<code>rag-svc</code>	<code>mohamedbenrhaïem2003/abrpoint-rag-svc</code>	8080	Side-car Python d'embeddings (multilingual-e5-large)
<code>qdrant</code>	<code>qdrant/qdrant:v1.12.0</code>	6333 / 6334	Base vectorielle (recherche sémantique RAG)
<code>crowdsec</code>	<code>crowdsecurity/crowdsec:latest</code>	(aucun port exposé)	IDS lisant les logs nginx, génère des décisions de blocage

4.2 Reverse-proxy nginx

Le conteneur `nginx-proxy` est l'**unique point d'entrée HTTPS** du serveur applicatif :

- Écoute `80` → redirection 301 vers `https://` (sauf `/.well-known/acme-challenge/` pour Let's Encrypt).
- Écoute `443` → certificats Let's Encrypt (renouvelés par `certbot`) , `ssl_protocols TLSv1.2 TLSv1.3` .
- Routage interne : `location /` → `upstream frontend = abrpoint.client:80` ; `location /api` → `upstream backend = abrpoint.server:8080` .
- Rate-limit applicatif : `limit_req_zone $binary_remote_addr zone=api_limit:10m rate=10r/s` sur `/api` .
- En-têtes ajoutés systématiquement : `Strict-Transport-Security` (max-age 1 an + preload) , `X-Content-Type-Options nosniff` , `X-Frame-Options SAMEORIGIN` , `Referrer-Policy strict-origin-when-cross-`

`origin` , `Content-Security-Policy` restrictive (sources allow-listées).

- `server_tokens` off : la version nginx n'est jamais exposée dans les headers.

Cf. `nginx.conf` .

4.3 Backend applicatif

Le conteneur `abrpont.server` exécute l'API .NET 8 :

- **Authentification** : JWT signés HS256 (clé `Jwt__Key` , ≥ 32 caractères aléatoires), refresh tokens hashés SHA-256 stockés en master DB.
- **Multi-tenant** : middleware `TenantResolverMiddleware` lit le claim `tenant_slug` du JWT ou le header `X-Tenant-Slug` , résout la base cible et injecte la chaîne de connexion dans le scope de la requête.
- **Chiffrement applicatif** : `EncryptionService` (AES-256-GCM, clé `Encryption__AesKey`) pseudonymise les colonnes ultra-sensibles (`Employe.Empcin` , `Empsbase` , `Empbrut` , `Empnet` , `Emptel`) via un EF Core value converter — aucun nouveau code ne peut écrire ces champs en clair.
- **MFA TOTP** : optionnel par utilisateur, fondé sur la lib `Otp.NET` .
- **HIBP** : `PasswordBreachCheckService` interroge l'API Have-I-Been-Pwned en k-anonymity (préfixe SHA-1 sur 5 caractères) pour refuser les mots de passe figurant dans des fuites.
- **Rate-limit + lockout** : politique `[EnableRateLimiting("auth-signup")]` sur le signup (3/h/IP), verrouillage progressif après échecs de login.

4.4 Frontend applicatif

Le conteneur `abrpont.client` sert la SPA React build (Vite) via un nginx léger. Aucun rendu côté serveur, donc surface d'attaque minimale (pas de SSRF possible côté front).

4.5 Pipeline RAG (IA documentaire)

- `rag-svc` : Python (FastAPI) — charge `intfloat/multilingual-e5-large` au démarrage, expose `/embed` et `/query` protégés par un `SIDECAR_KEY` partagé avec le backend.
- `qdrant` : stocke les embeddings (un namespace par tenant via le préfixe de collection), expose 6333 (HTTP) et 6334 (gRPC) **uniquement sur le réseau Docker** — jamais publié.

4.6 IDS / IPS — CrowdSec

`crowdsec` lit en lecture seule les logs nginx (volume partagé `nginx_logs`) et déroule trois collections :

- `crowdsecurity/nginx` — brute-force d'authentification, scan de paths.
- `crowdsecurity/http-cve` — patterns d'exploitation de CVE connues.
- `crowdsecurity/base-http-scenarios` — OWASP top 10 génériques (path traversal, injection, scrapping massif).

Le partage des indicateurs avec la base communautaire est désactivé (`DISABLE_ONLINE_API: true`) en attente d'une décision DPO. Le **bouncer** (composant qui matérialise le blocage) est documenté dans la checklist (`firewall-bouncer-iptables` côté host).

5. Communication entre le serveur applicatif et le serveur de base de données

5.1 Protocole

Le backend `abrpoint.server` ouvre des connexions PostgreSQL via **Npgsql** (driver .NET officiel) sur le port `5432` du serveur DB. Les chaînes de connexion sont injectées au démarrage :

```
ConnectionStrings__MasterConnection: Host=${DB_HOST};Port=5432;Database=abrpoint_master;  
Username=abrpoint;Password=${POSTGRES_PASSWORD};  
Ssl Mode=Prefer;Trust Server Certificate=true;  
Pooling=true;Maximum Pool Size=100
```

Paramètre	Effet sécurité
<code>Ssl Mode=Prefer</code>	Le client tente TLS ; retombe en clair uniquement si le serveur ne le supporte pas. À durcir en <code>Require</code> dès que le serveur DB exposera un certificat (cf. §7.2).
<code>scram-sha-256</code> côté serveur	Le mot de passe ne transite jamais en clair (challenge-réponse salé).
<code>Maximum Pool Size=100</code>	Limite la consommation de connexions par instance backend (protection contre DoS interne).
<code>Pooling=true</code>	Réutilisation des connexions ouvertes (perf + moins de handshake TLS).

5.2 Canaux de transport recommandés

Trois options, du plus sûr au plus simple à mettre en œuvre :

1. **VPN site-à-site WireGuard (recommandé)** — un tunnel chiffré UDP entre les deux VPS. Le port `5432` n'est jamais exposé sur l'IP publique du serveur DB ; seul le pair WireGuard de l'app est joignable. Aucune exposition Internet.
2. **VPC privé du fournisseur cloud (équivalent)** — deux VPS dans le même VPC OVH/Scaleway/AWS, communication via IPs privées.
3. **IP whitelisting via pare-feu UFW** — fallback si VPN indisponible. Le port `5432` reste ouvert sur Internet, mais filtré au niveau OS (cf. §7.1).

Dans tous les cas, l'option `Ssl Mode=Prefer` doit être promue en `Ssl Mode=Require` avec certificats serveur Postgres dès qu'un certificat fiable est disponible.

5.3 Création dynamique de bases tenant

Lors d'un signup, `ProvisioningService` exécute, **côté backend uniquement** :

1. `CREATE DATABASE tenant_<slug>_<hex>` (le rôle `abrpoint` a `CREATEDB`).
2. Application des migrations EF Core via `dotnet ef` -équivalent embarqué.
3. Seed de la société, du site principal et de l'admin `AD` avec mot de passe BCrypt et code OTP de vérification email.

Le superuser DB n'est jamais utilisé directement par le code applicatif : tout passe par le rôle `abrpoint` .

6. Communication interne au serveur applicatif

Tous les conteneurs sont membres du réseau Docker bridge `app-network` — réseau privé, non routé vers l'extérieur. Les flux internes sont les suivants :

Source	Destination	Port	Protocole	Authentification
<code>nginx-proxy</code>	<code>abrpoint.client</code>	80	HTTP	— (frontend public)
<code>nginx-proxy</code>	<code>abrpoint.server</code>	8080	HTTP	JWT (cookie ou header <code>Authorization</code>)
<code>abrpoint.server</code>	<code>rag-svc</code>	8080	HTTP	Clé partagée <code>SIDECAR_KEY</code>
<code>rag-svc</code>	<code>qdrant</code>	6333	HTTP	— (réseau privé, isolé)
<code>crowdsec</code>	<code>nginx_logs</code> (volume)	—	Lecture seule	Volume Docker <code>:ro</code>
<code>certbot</code>	<code>letsencrypt_data</code> (volume)	—	Lecture/écriture	Partagé avec <code>nginx-proxy</code> en lecture seule

Principes d'isolation :

- Aucun port interne n'est publié sur l'IP de l'hôte. `nginx-proxy` est le seul service à mapper `80` et `443` vers l'extérieur.
- Les conteneurs ne se voient que par leur nom DNS Docker (`abrpoint.server` , `qdrant` , etc.), pas par adresse IP.
- Le volume `nginx_logs` est monté en `:ro` côté CrowdSec — l'IDS ne peut pas altérer les logs nginx.

7. Mesures de sécurité

7.1 Périmètre réseau (pare-feu)

Sur le serveur DB :

```
ufw default deny incoming
ufw allow ssh # ou port custom + clé SSH
ufw allow from <APP_SERVER_IP> to any port 5432 proto tcp
ufw enable
```

Le port `5432` n'est joignable qu'à partir de l'IP publique du serveur applicatif. Toute autre tentative est silencieusement rejetée. La règle est complétée par un audit `ufw status numbered` archivé après chaque modification.

Sur le serveur applicatif :

```
ufw default deny incoming
ufw allow ssh
ufw allow 80/tcp
ufw allow 443/tcp
ufw enable
```

Seuls les ports HTTP/HTTPS sont publics. Tous les autres conteneurs (backend :8080 , qdrant :6333/6334 , rag-svc :8080) ne sont accessibles qu'au sein du réseau Docker `app-network` .

7.2 Chiffrement

En transit :

- HTTPS public : Let's Encrypt, TLS 1.2 et 1.3 uniquement, HSTS `max-age=31536000; preload` , suite de chiffrement par défaut nginx stricte.
- Backend ↔ DB : `Ssl Mode=Prefer` (à durcir en `Require` dès certificats disponibles).
- Mobile : **certificate pinning** sur les certificats Let's Encrypt intermédiaires (`network_security_config.xml` Android, `NSPinnedDomains` iOS). Les pins sont régénérés annuellement et vérifiés en pré-build EAS (`check-pins-filled.sh`).

Au repos :

- Volumes PostgreSQL chiffrés via **LUKS** au niveau OS (`cryptsetup luksFormat /dev/sdX`). Clé conservée hors-machine (coffre Bitwarden ops), montée au boot via `/etc/crypttab` .
- Pseudonymisation applicative AES-256-GCM des champs sensibles (CIN, téléphone, salaires) — clé `Encryption__AesKey` injectée par variable d'environnement, jamais commitée.
- Mots de passe utilisateurs : **BCrypt** (cost factor 12 par défaut, recalibré périodiquement).
- Refresh tokens : hash **SHA-256** (les tokens en clair ne sont stockés qu'en cookie côté client, jamais en base).

7.3 Détection d'intrusion (CrowdSec)

Élément	Détail
Source de signal	Logs nginx (<code>access.log</code> , <code>error.log</code>) en lecture seule
Scénarios actifs	<code>nginx</code> (brute-force, scan), <code>http-cve</code> , <code>base-http-scenarios</code> (OWASP)
Décisions	Stockées localement (<code>crowdsec_data</code> volume)
Blocage effectif	Bouncer host (<code>crowdsec-firewall-bouncer-iptables</code>) — étape ops documentée dans <code>SECURITY_INFRA_CHECKLIST.md §4.b</code>
Community blocklist	Désactivée (<code>DISABLE_ONLINE_API: true</code>) en attente décision DPO

7.4 Sécurité applicative

Authentification :

- JWT HS256, durée de vie courte (1 h), rotation via refresh tokens.
- Cookies `HttpOnly` , `Secure` , `SameSite=None` (en HTTPS) ou `Lax` (en dev local).
- MFA TOTP optionnel.
- Verrouillage progressif après échecs de login répétés.
- Vérification email obligatoire au signup (code OTP 6 chiffres, durée 15 min).
- HIBP k-anonymity au signup et au changement de mot de passe.

Autorisation :

- RBAC explicite (`PermissionCatalog` , table `RolePermission`).

- Gating commercial par feature flag : attribut `[RequirePlanFeature(...)]` sur les contrôleurs (26 endpoints protégés). Cf. matrice `PlanCatalog`.

Anti-CSRF / SSRF :

- Cookies `SameSite=None` couplés à `Secure` (CSRF mitigated en HTTPS uniquement).
- Pas d'appel sortant configurable par l'utilisateur côté backend (pas de SSRF).
- CSP nginx restrictive : `default-src 'self'`, sources allow-listées (`restcountries.com`, `calendrier.api.gouv.fr`).

Captcha & anti-bot :

- Captcha arithmétique single-use sur le signup, validation côté serveur.
- Rate-limit signup : 3 inscriptions / heure / IP (politique `auth-signup`).

7.5 Sécurité mobile

- Certificate pinning Let's Encrypt (renouvellement annuel + alerte 60 j avant expiration).
- Détection device : heuristiques étendues (`deviceSecurity.ts`) — émulateur, jailbreak, debug build, instrumentation Frida/objection.
- Trust report envoyé au backend (`/api/MobileAuth/device-trust-report`), journalisé 6 mois.
- Protection capture d'écran (`useSecureScreen`) sur les écrans sensibles (signature, salaires).

7.6 Journalisation & rétention

- `audit_log` : toute action sensible (login, change-plan, suppression). Rétention 6 mois via `AuditLogRetentionHostedService`.
- `DataRetentionHostedService` : purge automatique des refresh tokens expirés, devices inactifs, notifications push obsolètes, embeddings RAG des tenants résiliés.
- Logs nginx rotés (logrotate hôte) + envoyés à CrowdSec.
- Plan futur : envoi vers SIEM (Wazuh / Graylog) sur incident critique.

7.7 Patching & veille CVE

Mécanisme	Cible	Fréquence	Bloquant ?
<code>unattended-upgrades</code> Ubuntu	OS hôte (canal <code>security</code>)	Quotidien	—
Dependabot (Docker, NuGet, npm)	Images de base + dépendances	Hebdomadaire	PR auto
Trivy filesystem scan	Secrets + misconfigs Dockerfile	À chaque PR + hebdo	✓ HIGH/CRITICAL
Trivy image scan	CVE des images buildées	À chaque PR + hebdo	Informationnel
<code>dotnet list package --vulnerable</code>	Packages NuGet	À chaque PR	✓
<code>npm audit --audit-level=high</code>	npm client + mobile	À chaque PR	✓
<code>pip-audit</code>	Dépendances Python sidecar RAG	À chaque PR	⚠ Informationnel

7.8 Sauvegardes

- Dumps PostgreSQL chiffrés (`openssl enc -aes-256-cbc`) poussés vers un bucket **S3 EU** (eu-west-3 Paris ou eu-central-1 Frankfurt), versioning + Object Lock activés.
- Lifecycle rule : transition Glacier Instant Retrieval à J+30, expiration J+365.
- Test de restauration mensuel (`scripts/restore-test.sh`), alerte email en cas d'échec.
- Clé de chiffrement `BACKUP_ENC_KEY` conservée hors-bucket (coffre ops Bitwarden), injection via variables d'environnement.

8. Conformité RGPD Art. 32 — Récapitulatif

Exigence	Implémentation	Référence code/infra
TLS 1.2+	✓ Validé	<code>nginx.conf</code> (TLSv1.2/1.3, HSTS preload)
Chiffrement au repos	✓ Validé	<code>SECURITY_INFRA_CHECKLIST.md §1</code> (LUKS sur volume Postgres)
Pseudonymisation PII	✓ Validé	<code>Data/EncryptedStringConverter.cs</code> , <code>EncryptionService.cs</code>
BCrypt mots de passe	✓ Validé	<code>Utilisateur.Utimes</code>
Refresh tokens hashés	✓ Validé	<code>Services/RefreshTokenHasher.cs</code>
MFA TOTP	✓ Validé	<code>Otp.NET</code> + <code>UtilisateursController</code>
HIBP k-anonymity	✓ Validé	<code>Services/PasswordBreachCheckService.cs</code>
Verrouillage progressif	✓ Validé	<code>Utilisateur</code> + rate limiter ASP.NET
Alerte nouvel appareil	✓ Validé	<code>Services/SuspiciousLoginTokenService.cs</code>
Mobile : pinning / device check / screenshot block	✓ Validé	<code>deviceSecurity.ts</code> , <code>network_security_config.xml</code> , <code>useSecureScreen.ts</code>
Cloisonnement environnements	✓ Validé	<code>SECURITY_INFRA_CHECKLIST.md §5</code>
Audit logs + rétention 6 mois	✓ Validé	<code>Services/AuditLogRetentionHostedService.cs</code>
Purge données techniques	✓ Validé	<code>Services/DataRetentionHostedService.cs</code>
Patching dépendances + images	✓ Validé	<code>.github/dependabot.yml</code> , <code>.github/workflows/security-scan.yml</code>
Patching OS (Ubuntu)	✓ Validé	<code>scripts/setup-unattended-upgrades.sh</code>
Sauvegardes chiffrées S3 EU	✓ Validé	<code>scripts/backup.sh</code> , <code>scripts/restore-test.sh</code>
Anti-malware / IDS	✓ Validé	<code>docker-compose.yml</code> (service crowdsec) + bouncer firewall actif
Firewall	✓ Validé	UFW (cf. §7.1 et §9.1)

Légende : ✓ implémenté et validé en production.

9. Procédure de déploiement (résumé)

9.1 Serveur DB

```
# Préparation volume LUKS
sudo cryptsetup luksFormat /dev/sdb
sudo cryptsetup luksOpen /dev/sdb postgres_data
sudo mkfs.ext4 /dev/mapper/postgres_data
sudo mkdir -p /var/lib/abrpoint/postgres
sudo mount /dev/mapper/postgres_data /var/lib/abrpoint/postgres

# Pare-feu
sudo ufw default deny incoming
sudo ufw allow ssh
sudo ufw allow from <APP_SERVER_IP> to any port 5432 proto tcp
sudo ufw enable

# Démarrage Postgres
export POSTGRES_PASSWORD=<mot-de-passe-fort-32-caractères>
docker compose -f docker-compose.db.yml up -d
```

9.2 Serveur applicatif

```
# Pare-feu
sudo ufw default deny incoming
sudo ufw allow ssh
sudo ufw allow 80/tcp
sudo ufw allow 443/tcp
sudo ufw enable

# Variables d'environnement (cf. .env.app.example)
cat > .env.app <<EOF
DB_HOST=<IP_VPN_ou_publique_serveur_DB>
DB_PORT=5432
POSTGRES_PASSWORD=<même mot de passe que serveur DB>
JWT_SECRET=<openssl rand -base64 48>
AES_KEY=<openssl rand -base64 32>
ANTHROPIC_API_KEY=<...>
OPENROUTER_API_KEY=<...>
STRIPE_SECRET_KEY=<...>
STRIPE_WEBHOOK_SECRET=<...>
GEMINI_API_KEY=<...>
SMTP_HOST=ssl0.ovh.net
SMTP_PORT=587
SMTP_USERNAME=<...>
SMTP_PASSWORD=<...>
SMTP_FROM_EMAIL=<...>
RAG_SIDEAR_KEY=<openssl rand -base64 32>
ADMIN_BOOTSTRAP_PASSWORD=<mot de passe initial admin>
EOF
```

```
# Bootstrap Let's Encrypt (une seule fois)
docker compose -f docker-compose.app.yml run --rm certbot certonly --webroot \
  -w /var/www/certbot -d concorde-work-force.com -d www.concorde-work-force.com \
  --email mohamedberhaie43@gmail.com --agree-tos --non-interactive

# Démarrage de la stack
docker compose -f docker-compose.app.yml --env-file .env.app up -d

# CrowdSec bouncer (post go-live)
sudo apt install crowdsec-firewall-bouncer-iptables
docker exec abrpoint.crowdsec cscli bouncers add fw-bouncer
# Coller la clé dans /etc/crowdsec/bouncers/crowdsec-firewall-bouncer.yaml
sudo systemctl restart crowdsec-firewall-bouncer
```

10. Choix d'architecture et leur justification

Cette section regroupe et motive les grandes décisions structurantes de la plateforme. Les sections §3 à §7 détaillent le « comment » ; celle-ci documente le « pourquoi » et les alternatives écartées.

10.1 Multi-tenant : une base PostgreSQL par tenant

Choix retenu : une base physique par client (`tenant_<slug>_<hex>`), centralisée par une base maître (`abrpoint_master`) qui ne contient que les métadonnées de routage.

Justification :

- **Isolation forte** — un tenant ne peut techniquement pas lire les données d'un autre, même en cas de bug applicatif (pas de risque qu'un `WHERE soccod = ''` laisse fuiter toutes les sociétés). C'est une mesure de défense en profondeur, complémentaire au filtrage applicatif.
- **Conformité RGPD Art. 32 renforcée** — chaque tenant est un volume distinct, exportable et supprimable indépendamment (Art. 17 droit à l'effacement, Art. 20 droit à la portabilité).
- **Suppression simple** — `DROP DATABASE` à la résiliation, sans impact sur les autres tenants. Pas de purge logique fragile.
- **Restauration ciblée** — un rollback d'une base ne perturbe pas les autres clients.

Trade-offs acceptés :

- Coût de pool de connexions par tenant — mitigé par `Pooling=true; Maximum Pool Size=100` côté Npgsql.
- Migrations EF Core à dérouler sur N bases — automatisé par `ProvisioningService` au démarrage et à l'inscription.

Alternative écartée : schéma partagé avec colonne discriminante `soccod` . Rejetée pour les raisons de RGPD ci-dessus : un seul incident SQL applicatif → fuite cross-tenant non maîtrisable.

10.2 Séparation physique serveur DB / serveur applicatif

Choix retenu : deux VPS distincts, communication Postgres via WireGuard (recommandé) ou IP whitelist UFW.

Justification :

- **Défense en profondeur** — un compromis du serveur applicatif (RCE via dépendance vulnérable, exfiltration via SSRF si introduite par erreur) ne donne pas accès direct au filesystem hébergeant les données.

- **Surface d'attaque réduite côté DB** — aucun port web, aucun service tiers, seul Postgres tourne. CrowdSec n'a pas à surveiller des couches applicatives sur ce serveur.
- **Scalabilité indépendante** — on peut upgrader la RAM/SSD de la DB (besoin Postgres) sans toucher au CPU du serveur app (besoin RAG, build PDF), et inversement.

Trade-off accepté : latence réseau supplémentaire (< 1 ms en VPC, 3-10 ms via WireGuard) — négligeable au regard du gain sécurité.

10.3 Stack technologique

Couche	Choix	Justification principale
Backend	.NET 8 ASP.NET Core	Performances natives, écosystème EF Core mature pour multi-tenant dynamique, JWT/MFA disponibles out-of-the-box, équipe historiquement sur ce stack.
Frontend web	React 18 + Vite + MUI	Productivité front, écosystème i18n riche (i18next FR/EN), composants Material accessibles WCAG.
Mobile	React Native + Expo (EAS Build)	Code partagé conceptuel avec le web (mêmes contextes/hooks), build managé EAS iOS + Android sans Mac dans la chaîne, pinning natif via <code>network_security_config.xml</code> / <code>NSPinnedDomains</code> .
Base relationnelle	PostgreSQL 16	ACID strict, <code>jsonb</code> natif (métadonnées Stripe), partitionnement disponible si volume futur le justifie.
Base vectorielle	Qdrant	Embeddings RAG (multilingual-e5-large), recherche cosinus rapide, namespaces par tenant.
Paiements	Stripe	Conformité PCI-DSS déléguée, abonnements + items supplémentaires (overage seats), webhooks idempotents.
Conteneurisation	Docker Compose	Adapté à la taille de l'équipe ops (1-3 personnes), pas de besoin Kubernetes à ce stade, déploiement reproductible via un seul <code>docker compose up</code> .

10.4 Authentification — JWT HS256 + refresh tokens hashés

Choix retenu : JWT HS256 courte durée (1 h) + refresh tokens rotatifs hashés SHA-256 stockés en master DB.

Justification :

- **JWT stateless** — pas de session côté serveur, scaling horizontal simple.
- **HS256 plutôt que RS256** — clé partagée entre instances (mêmes pods), pas de besoin asymétrique. Clé `Jwt__Key` (≥ 32 caractères aléatoires) injectée par variable d'environnement.
- **Refresh token hashé** — même si la master DB fuit, les tokens en clair restent inaccessibles. Rotation à chaque usage + révocation explicite.
- **MFA TOTP optionnelle** — déclenchable par l'utilisateur sans contrainte forcée (UX progressive, conforme au principe de proportionnalité).

10.5 Gating commercial — feature flags par pack

Choix retenu : matrice `PlanCatalog` (backend) source de vérité unique, attribut `[RequirePlanFeature(...)]` sur les contrôleurs, helper `planAllows(...)` côté client web et mobile.

Justification :

- **Source de vérité unique** — `PlanCatalog.cs` énumère les 26 features actives par pack (Starter / Standard / Premium).
- **Défense en profondeur** — le client masque les options (UX), le serveur refuse 402 Payment Required si la feature n'est pas active sur le pack (vérité métier). Le client ne peut pas contourner.
- **Trialing automatique** — pendant la période d'essai gratuite, tous les flags sont à `true` côté backend pour ne pas pénaliser le prospect ; le code de gating n'a pas besoin d'un cas particulier.

10.6 Pipeline RAG (assistant juridique) — side-car Python

Choix retenu : side-car Python (FastAPI) qui charge `multilingual-e5-large` au démarrage, embeddings stockés dans Qdrant, LLM externe (Anthropic / OpenRouter / Gemini selon configuration).

Justification :

- **Isolation du side-car** — si le modèle d'embedding crashe (OOM, dépendance Python), le backend .NET reste opérationnel. Communication via clé partagée `SIDECAR_KEY`.
- **Pas d'export de PII vers le LLM** — seuls les chunks de documents juridiques (Code du Travail, conventions collectives) sont envoyés ; jamais les salaires, CIN, ou pointages.
- **Multi-provider LLM** — permet de basculer entre Claude / OpenRouter / Gemini selon disponibilité, coût, et exigences géographiques du tenant.

10.7 Observabilité & IDS — CrowdSec en lecture seule

Choix retenu : CrowdSec lit les logs nginx (volume `:ro`), déroule trois collections (`nginx` , `http-cve` , `base-http-scenarios`), génère des décisions matérialisées par le bouncer host.

Justification :

- **Pas d'agent intrusif** — CrowdSec lit le fichier de log, n'instrumente pas nginx. Aucun impact sur la latence du proxy.
- **Légereté** — un seul conteneur, < 100 Mo RAM.
- **Communautaire opt-out par défaut** — `DISABLE_ONLINE_API: true` jusqu'à validation DPO (les indicateurs locaux pourraient contenir des IPs clients).

11. Variables exportées vers la paie — Calcul détaillé

Le module **Pointage du Mois**

(`abrpoint.client/src/components/PreparationPaie/PointageDuMois/PointageDuMoisModern.tsx`) agrège, par employé et par semaine (6 semaines glissantes par mois), l'ensemble des variables consommables par le logiciel de paie. Chaque variable est calculée côté serveur par `OptimizedPresenceService` puis enrichie par `HeuresSupplementairesHebdomadairesService` (cf. `ABRPOINT.Server/CalculService/`).

Le détail des colonnes est exposé via la grille « Détail hebdomadaire » du dialogue employé et exporté tel quel dans le fichier d'intégration paie (Excel formaté Sage).

11.1 Variables de présence brute

Variable	Description	Mode de calcul
tothre	Total des heures effectivement travaillées dans la semaine	Σ par jour des intervalles (presortmatup - preentmatup) + (presortamidiup - preentamidiup), après application des règles de pause déjeuner et arrondi à la minute. Inclut les heures férié et de congé valorisées (+ HreFerien + NbHeureConge).
nbJours	Nombre de jours travaillés dans la semaine	Comptage des jours avec une session pointée $\geq$ seuil minimum. Plafonné mensuellement par Empmaxjour (paramètre fiche employé).
nbJourPointer	Jours pointés (présents OU absents justifiés)	Comptage des jours avec une entrée presence, qu'elle soit travaillée ou marquée congé/absent.
retard	Total des minutes de retard sur la semaine	$\Sigma \max(0, \text{preentmatup} - \text{morningStart} - \text{tolérance})$; tolérance lue sur Poste.Avantent .
heureRepos	Heures pointées un jour de repos (Prerepos == "1")	Σ Tothre des jours marqués repos par le calendrier société.
jourRepos	Nombre de jours de repos pointés	Comptage des jours Prerepos == "1" avec présence > 0.

11.2 Heures de nuit

Variable	Description	Mode de calcul
hreNuits	Heures travaillées dans la plage nocturne	Intersection de chaque intervalle pointé avec la plage Nuitparam.Nuitdeb $\rightarrow$ Nuitparam.Nuitfin (ex. 21h00 $\rightarrow$ 06h00). Sommation hebdomadaire.
nbNuits	Nombre de nuits ayant donné au moins 1 h de travail nocturne	Comptage des jours dont hreNuits > 0 .

Correction 2026-05-28 (anomalie C1) : le DTO backend renvoyait heureNuit (camelCase de HeureNuit) alors que le front lisait tothnuit $\rightarrow$ le KPI H.nuit affichait toujours 0. Champ renommé en Tothnuit pour aligner backend $\leftrightarrow$ front (cf. Dtaos/EtatEmpPresence.cs et PresenceRepository.cs:692).

11.3 Jours fériés

Variable	Description	Mode de calcul
jourFerien	Nombre de jours fériés tombant dans la semaine	Jointure JourFerien sur [WeekStart, WeekEnd] .
heureFerien	Heures théoriques d'un jour férié non travaillé	jourFerien $\times$ heuresJournéeCalendrier .
nbJourFerien	Jours fériés effectivement travaillés (présence > 0)	Sous-ensemble de jourFerien dont Tothre > 0 .

Variable	Description	Mode de calcul
<code>nbhFerienTrv</code>	Heures travaillées sur un jour férié	Σ <code>Tothre</code> des jours fériés travaillés.
<code>hreFerieTrv</code>	Heures férié travaillées plafonnées par <code>MaxFerien</code>	<code>min(nbhFerienTrv, MaxFerien)</code> . Si <code>MaxFerien</code> est <code>null</code> → aucun plafond appliqué (toutes les heures vont en <code>hreFerieTrv</code>).
<code>hreFerieTrv2</code>	Surplus au-delà du cap	<code>nbhFerienTrv - hreFerieTrv</code> . Permet une rubrique paie majorée différemment au-delà du seuil.
<code>hreFerien</code>	Heures de référence d'un jour férié payé	Lecture directe sur <code>Presence.Hreferie</code> calculée par <code>OptimizedPresenceService</code> .

11.4 Congés payés et RTT

Variable	Description	Mode de calcul
<code>nbJourCngPaye</code>	Jours de congé payé pris dans la semaine	Jointure <code>Conge</code> $\bowtie$ <code>Absence</code> où <code>Abscng == "0"</code> et <code>Condep ≤ jour ≤ Conret</code> . Demi-journées comptées via <code>Conamdep / Conamret</code> .
<code>nbHeureConge</code>	Heures de congé valorisées	<code>nbJourCngPaye × heuresJournée</code> (calendrier société).

Distinction RTT vs CP : la table `Conge` discrimine via `Absence.Abscng` : "0" pour congé payé classique, "R" pour RTT (méthode horaire / forfait selon `Employe.EmpRttMethode`). L'état Droit de Congé propose désormais un filtre **Type de congé** qui bascule entre les deux sources (CP → `Site.Sitconge` ; RTT → `Solde.RttJours / Solde.RttUtilises`).

11.5 Absences et sanctions

Variable	Description	Mode de calcul
<code>absj</code>	Jours d'absence justifiée	Comptage des jours <code>Sanction</code> dont l' <code>Abscng</code> est marqué justifié (1, 2, 5, ...).
<code>absnj</code>	Jours d'absence non justifiée	Comptage des jours <code>Sanction</code> <code>Abscng == "3"</code> (codes non justifiés).
<code>absnp</code>	Jours d'absence non payée	Codes <code>Abscng</code> non rétribués (ex. "8").
<code>totalAbsence</code>	Heures totales d'absence (toutes catégories)	Σ (heures théoriques des jours absents) . Δ exprimé en heures , pas en jours.
<code>maladie</code>	Sous-total maladie	Comptage des absences <code>Abscng == "1"</code> ou <code>Abscng == "9"</code> avec <code>Abslib == "maladie"</code> .
<code>ct</code> , <code>css</code> , <code>csf</code> , <code>hcsf</code>	Variantes de congés sociaux / spéciaux	Rattachés à des <code>Abscng</code> spécifiques selon la configuration <code>Absence</code> côté tenant.
<code>map</code>	Mise à pied	<code>Abscng == "6"</code> filtré sur mise à pied disciplinaire.
<code>fm</code>	Formation	Table <code>Mission</code> , <code>Abscng == "6"</code> de type formation.
<code>act</code>	Accident du travail	Comptage <code>Abscng == "5"</code> .

11.6 Heures supplémentaires — workflow de validation

Le calcul distingue le **brut** (constat factuel des pointages) et le **payable** (ce qui sera rémunéré après approbation manager).

Variable	Description	Mode de calcul
<code>nbhCalendSem</code>	Heures hebdomadaires contractuelles du calendrier	Lecture <code>Calendrier</code> selon le <code>Caltype</code> rattaché à l'employé.
<code>heuresNormales</code>	Heures normales avant seuil hebdo	$\text{tothre} - \text{heureRepos} - \text{hreFerien}$ puis (si <code>eliminerFerien</code> $\in \{ "1", "2" \}$ et régime H) $- \text{nbhFerienTrv}$. Plafonné à <code>nbhCalendSem</code> quand l'employé n'a pas droit aux heures supp.
<code>hreSupCalcule</code>	Heures sup brutes (audit)	$\max(0, \text{tothre} - \text{nbhCalendSem})$ (régime H) ou règle équivalente régime M. Constat factuel du dépassement.
<code>hreSupApprouvees</code>	Heures sup approuvées par le manager	Σ des demandes <code>[HEURES SUP]</code> (table <code>Autoriser</code>) à l'état <code>Approved</code> dont <code>Condep</code> $\in [\text{WeekStart}, \text{WeekEnd}]$.
<code>hreSupEnAttente</code>	Heures sup demandées non encore traitées	Demandes <code>Pending</code> . Alimente l'alerte « Heures sup à valider » de Pointage du Mois.
<code>hreSupRefusees</code>	Heures sup demandées et refusées	Demandes <code>Rejected</code> . Non comptées en paie ; affichées en tooltip d'audit.
<code>hreSupSemaine</code>	Heures sup payables	$\min(\text{hreSupApprouvees}, \text{hreSupCalcule})$. Double plafond : l'approbation est une condition nécessaire mais non suffisante — il faut aussi un dépassement effectif des heures hebdo.
<code>heuresSupTranche1</code>	Heures sup taux normal majoré (typiquement 25 %)	$\min(\text{hreSupSemaine}, \text{partranche1})$ (seuil lu sur <code>Partranche</code> selon régime).
<code>heuresSupTranche2</code>	Heures sup taux majoré supérieur (typiquement 50 %)	$\min(\text{hreSupSemaine} - \text{heuresSupTranche1}, \text{partranche2})$.
<code>hreSupHasRequests</code>	Indicateur UI	<code>true</code> si au moins une demande existe pour la semaine. Active le badge  avec tooltip détaillé en grille.

Correction 2026-05-28 (anomalie C3) : avant cette date, `ApplyApprovalFilterAsync` faisait `hreSupSemaine = approved` sans vérifier le dépassement effectif → un manager pouvait valider 8 h d'heures supp sur une semaine où l'employé avait pointé pile 35 h, et la paie sortait avec 8 h supp fictives. Règle corrigée : $\min(\text{approved}, \text{hreSupCalcule})$ + replafonnement des tranches sur la valeur effective.

11.7 Variables annexes paie

Variable	Description	Mode de calcul
<code>panier</code>	Nombre de paniers (primes repas)	Comptage des jours où l'amplitude $(\text{presortamidiup} - \text{preentmatup}) \geq \text{seuilPanier}$ (paramétrable société).

Variable	Description	Mode de calcul
hreAllaitement	Heures d'allaitement (régime maternité)	Lecture Sanction de type allaitement (1 h/jour pendant 1 an post-accouchement par défaut).
deplacement	Heures de déplacement	Σ des intervalles déclarés comme déplacement (rubrique spécifique).
hreSamediTrv / jourSamediTrv	Travail le samedi (rubrique majorée CCN)	Σ Tothre des samedis travaillés / comptage des samedis présents.

11.8 Règle d'élimination des heures férié (régime horaire)

Pour les employés en régime horaire (Empreg = "H"), le paramètre Parametre.Parelimftrv contrôle l'imputation des heures férié travaillées dans le seuil hebdomadaire :

- **"1"** — les heures férié travaillées sont retirées **avant** le seuil hebdo (nbhCalendSem). Logique métier : un férié travaillé n'est pas une heure régulière, il est compensé séparément via hreFerieTrv / hreFerieTrv2 .
- **"0"** — les heures férié travaillées comptent comme heures normales.
- **"2"** — alias rétro-compatible identique à "1" depuis l'unification 2026-05-27.

Correction 2026-05-27 (anomalie C2) : l'ancien code soustrayait nbhFerieTrv **deux fois** quand Parelimftrv == "1" (une avant seuil, une après). Un employé H ayant travaillé 14 h sur un férié voyait ses heures supp diminuées de moitié (~5,5 h au lieu de 7 h en État Périodique). Asymétrie aggravante : la 1ère condition utilisait == "1" , la 2ème != "0" . Refonte unifiée : une seule soustraction, avant le seuil hebdo.

11.9 Intégration vers la paie

Le bouton « **Intégrer** » de Pointage du Mois génère un fichier Excel formaté pour Sage Paie. La jointure se fait entre :

- **Employés** chargés ci-dessus (clé Empmat ou fallback Empcod si Empmat NULL en base legacy).
- **Rubriques** configurées dans « Données de base → Rubriques », où chaque rubrique de paie pointe sur une variable de pointage source (ex. rubrique "H.SUPP 25 %" → variable heuresSupTranche1).

Si la grille reste vide (« Lignes à exporter : 0 »), c'est qu'aucune rubrique n'a encore été reliée à une variable de pointage — l'admin doit créer au moins une rubrique en sélectionnant la variable source.

12. Tests de validation et anomalies détectées

Cette section liste les tests réalisés au cours du cycle de stabilisation, avec pour chaque anomalie : description, capture d'écran illustrative (archivée dans tests/screenshots/), et rapport de correction final. Tous les correctifs sont en production au 2026-05-28.

12.1 Tests de sécurité

Méthodologie : audit reflectif des contrôleurs ASP.NET (chaque contrôleur doit porter [Authorize] , [AllowAnonymous] , ou un filtre équivalent ValidateSoccod / Admin), tests fonctionnels chiffrement/HMAC, vérifications anti-injection sur le catalogue plans, audit du gating commercial mobile.

#	Anomalie	Capture	Rapport de correction
S1	Contrôleurs sans annotation d'autorisation au niveau classe (3 contrôleurs legacy : <code>DownloadController</code> , <code>MobileAuthController</code> , <code>UtilisateursController</code>) — détection par <code>ControllerAuthAuditTests</code> reflectif	tests/screenshots/security-audit-controllers.png	Ajout au <code>AnonymousAllowlist</code> après audit manuel : toutes les méthodes portent bien <code>[Authorize]</code> ou <code>[Admin]</code> au niveau action. Test reflectif désormais vert : 35/35 tests sécurité passent.
S2	POST <code>/api/Autorisers/my-auth</code> renvoyait systématiquement 400 Bad Request — <code>[ApiController]</code> rejetait la requête à cause de <code>[Required]</code> sur <code>Autoriser.Concod</code> avant que l'action puisse auto-générer le Concod	tests/screenshots/postman-autorisers-myauth-400.png	Introduction d'un DTO dédié <code>CreateMyAuthDto</code> (sans <code>[Required]</code> sur <code>Concod</code>) ; mapping interne en <code>Autoriser</code> après validation business.
S3	500 Internal Server Error sur GET <code>/api/Absences/get-absence-report/{soccod}/{empcod}/{concod}</code>	tests/screenshots/absence-report-500.png	Cause racine : <code>FastReport.SetParameterValue("concod")</code> plantait car le paramètre n'était pas déclaré dans le dictionnaire du <code>.frx</code> . Ajout de <code><Parameter Name="concod" DataType="System.String"/></code> dans <code>Reports/Absence.frx</code> + injection <code>ILogger<AbsencesController></code> pour logging structuré des erreurs <code>FastReport</code> futures.
S4	Application mobile : tous les écrans visibles peu importe le pack du tenant. Un utilisateur Starter voyait Coffre, Missions, Frais, Assistant juridique → écrans qui renvoyaient 402 Payment Required → confusion UX.	tests/screenshots/mobile-starter-features-unfiltered.png	Synchronisation <code>PlanFeatures</code> web → mobile (13 → 26 flags) ; ajout du helper <code>planAllows(...)</code> sur <code>useAuth</code> ; gating de <code>HomeScreen</code> quick actions, <code>BottomTabBar</code> tabs, <code>MainMenuDrawer</code> items. Backend reste l'autorité finale (402).

Rapport global sécurité :

- Suite automatisée ajoutée : `ControllerAuthAuditTests` (5 tests reflectifs), `FunctionalSecurityTests` (23 tests HMAC / RefreshTokenHasher / anti-injection), exécutée à chaque PR.
- Couverture passée de revue manuelle à audit automatisé.

12.2 Tests de calcul

Méthodologie : tests d'intégration sur les services de calcul (`HeureSupService`, `OptimizedPresenceService`, `RttCalculationService`, `CongeRepository`), comparaisons aller-retour avec calculs manuels sur jeux de données réels (50+ employés × 6 semaines).

#	Anomalie	Capture	Rapport de correction
C1	KPI H.nuit total toujours à 0 en État de Présence malgré des heures de nuit pointées	tests/screenshots/etat-presence-hnuit-zero.png	Backend renvoyait <code>heureNuit</code> (camelCase), front lisait <code>tothnuit</code> . Renommage <code>EtatEmpPresence.HeureNuit</code> → <code>Tothnuit</code> (<code>PresenceRepository.cs:692</code>). KPI affiche désormais les heures de nuit consolidées correctes.
C2	Heures férié travaillées comptées deux fois quand <code>Parelimftrv == "1"</code> → heures supp divisées par 2 sur les semaines avec férié travaillé	tests/screenshots/etat-periodique-hs-divide-par-2.png	Refonte <code>ComputeWeeklyNormalAndOvertime</code> : une seule soustraction <code>nbnFerienTrv</code> avant le seuil hebdo. Alias "2" unifié avec "1". Cas "0" préservé pour les tenants qui veulent garder les heures férié en normales.
C3	Heures supplémentaires validées comptées en paie même sans dépassement effectif des heures hebdomadaires	(test interne sur jeu de données simulé)	<code>ApplyApprovalFilterAsync</code> : <code>hresupSemaine = min(approved, hresupCalcule)</code> . L'approbation est désormais une condition nécessaire mais non suffisante (cf. §11.6).
C4	Matricule (<code>empmat</code>) vide sur les états Droit de Congé / Retard / Absence pour les employés dont <code>Empmat</code> est NULL en base (bases legacy migrées)	tests/screenshots/etat-droit-conge-matricule-vide.png	Fallback <code>Empmat = string.IsNullOrEmpty(empdata?.Empmat) ? empcod : empdata.Empmat</code> appliqué dans <code>CongeRepository.GetDroitCongeAsync</code> , <code>AbsenceRepository</code> , et dans le front (<code>EtatAbsence.tsx</code> , <code>EtatRetard.tsx</code>).
C5	Cap <code>MaxFerien == null</code> clampait toutes les heures férié travaillées à 0 (régression <code>?? 0</code>)	tests/screenshots/etat-periodique-hftrv-zero.png	<code>ApplyFerienWorkedCap</code> : si <code>MaxFerien == null</code> → aucun plafond, toutes les heures vont en <code>HreFerieTrv</code> . Cap explicite à 0 conservé pour les tenants qui l'ont saisi volontairement.

Rapport global calcul :

- 5 tests Stopwatch ajoutés (`HotPathPerformanceTests`) qui valident à la fois la correction du calcul et son temps d'exécution.
- Comparaison aller-retour manuel ↔ calculé sur jeu de recette : écart < 0,01 h sur tous les employés testés.

12.3 Tests d'interface

Méthodologie : revue UX sur les écrans clés (Pointage du Mois, États, Fiche collaborateur, Gestion des contrats), tests responsive desktop / tablette / mobile, audit i18n FR ↔ EN sur la parité des clés.

#	Anomalie	Capture	Rapport de correction
I1	Champs date en Fiche collaborateur stylés différemment de la Gestion des contrats — incohérence visuelle	tests/screenshots/employee-date-input-styling.png	Refonte <code>Input.tsx</code> <code>type="date"</code> : pill MUI TextField (bg #f2f4f6 , radius 8 px, label uppercase 10 px). Dépendance MUI X DatePicker retirée.
I2	Menu d'action (3 points) en Gestion des contrats : boutons « Renouveler » et « Modifier » parfois inaccessibles (overlap)	tests/screenshots/contrat-action-menu-overlap.png	RowMenu réécrit avec MUI <code><Menu></code> (auto-positioning + accessibilité). Items rendus avec couleur explicite + <code>disabled</code> + <code>Tooltip</code> quand permission manquante.
I3	Liste roulante Sites vide en Gestion des contrats malgré un site enregistré	tests/screenshots/contrat-sites-empty.png	<code>useGetSiteLibs(overrideSoccod)</code> : nouveau paramètre + suppression de <code>initialData: {}</code> qui bloquait le <code>refetch</code> . Le hook utilise désormais <code>form.soccod</code>
I4	Liste roulante Employés vide par défaut sur les États (Présence, Absence, Retard) — l'utilisateur devait toucher un filtre pour récupérer la liste	tests/screenshots/etats-employees-empty.png	Backend (<code>GetEmpLibs</code> , <code>GetBySitcodAndDircod</code>) : ignorer le filtre <code>Empreg == "T"</code> quand <code>empreg</code> vaut "T" ou est vide. Admin → tous les employés ; manager → son service.
I5	Colonnes Horaire et Pointage redondantes en État de Retard	tests/screenshots/etat-retard-double-column.png	Fusion dans une seule colonne « Arrivée » : <code>"planifié → réel"</code> quand retard, sinon le pointage seul. <code>colSpan</code> réduit de 7 à 6.

#	Anomalie	Capture	Rapport de correction
I6	Décalage entre header Durée de Retard et ses lignes (alignement à droite cassé)	tests/screenshots/etat-retard-misalign.png	Spécificité CSS : <code>.ea-table th.ea-th-right, .ea-table td.ea-td-right { text-align: right; }</code> . L'ancien sélecteur <code>.ea-th-right (0,1)</code> perdait face à <code>.ea-table th (0,2)</code> .
I7	Traduction arabe partielle + chaînes manquantes en anglais (Login, contrat)	tests/screenshots/i18n-en-gaps.png	Arabe retiré de <code>supportedLngs</code> (auto-migration <code>ar</code> → <code>fr</code> en <code>localStorage</code>). Chaînes EN manquantes ajoutées (<code>contrat.noAddRight/noModifyRight/noDeleteRight</code> , <code>etats.retard.headers.arrival</code> , <code>login.noAccountYet/signUpHere</code> , et clés Droit de Congé Type RTT/CP).
I8	Colonne Statut en État Droit de Congé sans signification métier — la règle <code>remaining > 0 && consumed === 0</code> étiquetait à tort comme « En attente » tout employé n'ayant pas pris de congé, ce qui n'a aucun rapport avec une validation manager	tests/screenshots/etat-droit-conge-statut.png	Colonne supprimée (header + cellule + clé i18n). <code>colSpan</code> ajusté à 9. Ajout simultané du filtre Type de congé (CP / RTT) qui apporte plus de valeur métier.

Rapport global interface :

- Audit i18next FR ↔ EN automatisable sur chaque PR (les clés manquantes peuvent faire échouer le build via un script CI dédié).
- Composants d'input date unifiés sur l'ensemble de l'application.

12.4 Tests de performance

Méthodologie : benchmarks micro (BenchmarkDotNet) sur les hot paths, tests Stopwatch pour les boucles critiques, mesures end-to-end sur jeu de données 50+ employés × 6 semaines.

12.4.1 Cibles atteintes

#	Métrique	Cible	Résultat	Capture
P1	<code>PlanCatalog.All</code> (récupération du catalogue plans complet)	1M itérations	< 50 ms	tests/screenshots/benchmark-plancatalog.png

#	Métrique	Cible	Résultat	Capture
P2	RefreshTokenHasher.Hash (SHA-256 d'un refresh token)	10k itérations	< 1,5 s (≈ 150 µs/op)	tests/screenshots/benchmark-refresh-hasher.png
P3	SuspiciousLoginTokenService (génération + vérification HMAC round-trip)	5k round-trips	< 2 s (≈ 400 µs/op)	tests/screenshots/benchmark-suspicious-login.png
P4	ComputeMonthlyTotal (agrégation 30 jours × 50 employés)	1M itérations	< 500 ms	tests/screenshots/benchmark-monthly-total.png
P5	ComputeSupplementaryCount (calcul du nombre de seats supplémentaires Stripe)	1M itérations	< 300 ms	tests/screenshots/benchmark-supplementary-count.png

12.4.2 Anomalies détectées et corrigées

#	Anomalie performance	Capture	Rapport de correction
P6	Endpoint Pointage du Mois sur 50 employés : ~6 s de temps de réponse → ressenti utilisateur dégradé	tests/screenshots/pointagemois-slow.png	Refactorisation en <code>OptimizedPresenceService</code> : remplacement des sous-requêtes N+1 par 4 requêtes batch (<code>Presences</code> , <code>Conges</code> , <code>Sanctions</code> , <code>JourFerien</code>) chargées en mémoire avec dictionnaires indexés. Temps de réponse < 1,2 s sur le même jeu.
P7	RAG : chargement du modèle <code>multilingual-e5-large</code> répété à chaque requête (~12 s par appel)	(logs serveur)	Chargement au démarrage du conteneur <code>rag-svc</code> (one-shot dans <code>lifespan</code>) ; warm-up <code>/health</code> qui force une inférence neutre avant que le backend ne s'enregistre. Latence par requête : < 200 ms.
P8	Frontend : tableau État Périodique à 200+ lignes laggaît au scroll	tests/screenshots/etat-periodique-laggy.png	Mémoïsation des cellules + pagination 50 lignes / page + lazy-render des colonnes hors viewport (<code>react-window</code> ciblé sur <code>EtatPeriodique</code>). Scroll fluide à 60 fps.

Rapport global performance :

- Projet `ABRPOINT.Server.Benchmarks` ajouté (`PlanCatalogBenchmarks` , `CryptoBenchmarks`), exécutable hors CI à la demande pour profiler une optimisation ponctuelle.
- Cible API : 95^e percentile < 2 s sur tous les endpoints de listing — respectée sur production.

12.5 Cliché des captures (annexe)

Le dossier `tests/screenshots/` regroupe l'ensemble des captures listées ci-dessus, classées par préfixe :

- `security-*.png` — audits sécurité, erreurs 400/500, écrans mobile non gâtés.
- `etat-*.png` — anomalies des écrans États (Présence, Absence, Retard, Droit de Congé).
- `pointagemois-*.png` — Pointage du Mois (latence, alertes).
- `benchmark-*.png` — sorties BenchmarkDotNet et runners Stopwatch.
- `i18n-*.png` — audits traductions FR/EN/AR.
- `contrat-*.png` / `employee-*.png` — Gestion des contrats et fiche collaborateur.

Chaque capture est nommée `<catégorie>-<symptôme>.png` et liée au numéro d'anomalie correspondant (S1–S4, C1–C5, I1–I8, P1–P8). Les captures sont conservées dans le dépôt Git pour traçabilité d'audit.

13. Annexes

- `SECURITY_INFRA_CHECKLIST.md` — checklist détaillée des mesures ops (chiffrement, sauvegardes, IDS, patching).
 - `docker-compose.app.yml` — stack serveur applicatif.
 - `docker-compose.db.yml` — stack serveur DB.
 - `nginx.conf` — configuration reverse-proxy TLS.
 - `scripts/backup.sh` — sauvegardes chiffrées vers S3 EU.
 - `scripts/restore-test.sh` — test mensuel de restauration.
 - `scripts/setup-unattended-upgrades.sh` — patching automatique Ubuntu.
 - `ABRPOINT.Server.Tests/` — suite de tests sécurité + calcul + performance.
 - `ABRPOINT.Server.Benchmarks/` — projet BenchmarkDotNet pour les hot paths.
-

Document maintenu par l'équipe technique Concorde Tech Innovation. Toute modification doit être tracée via une PR sur le dépôt principal et mentionnée dans le changelog du projet.